GUÍA DE LABORATORIO

Wazuh como SIEM y HIDS - TryHackMe

UNIDAD	SESION	TIPO	HERRAMIENTAS
2	6	LABORATORIO	Wazuh | TryHackMe

CUGDL — Universidad de Guadalajara
Arquitectura de Sistemas de Seguridad
Licenciatura en Ciberseguridad

Autor: Carlos Pulido Rosas
Abril 2026

CONTEXTO	PASOS DEL LAB	ENTREGABLE
Usar Wazuh como SIEM y HIDS para detectar ataques en tiempo real, conectando la teoría de IDS/IPS con una	1. Crear cuenta TryHackMe 2. Acceder a la room Wazuh 3. Conectar al servidor 4. Explorar el dashboard 5. Analizar alertas de seguridad 6. (Reto) Crear regla personalizada	Capturas del dashboard con alertas identificadas + respuestas a preguntas de reflexión en .pdf

OBJETIVOS DEL LABORATORIO

1. Acceder al dashboard de Wazuh y navegar sus secciones principales: Security Events, Agents, Vulnerability Assessment y Rules.
2. Identificar y analizar alertas de seguridad reales generadas por los agentes monitoreados — login fallidos, cambios en archivos, escaneos de puertos.
3. Conectar cada alerta con el concepto teórico correspondiente: HIDS para eventos del host, correlación SIEM para patrones de ataque, severidad para priorización.
4. (Reto) Explorar el sistema de reglas de Wazuh y entender cómo una regla genera una alerta específica.

LABORATORIO

Antes de empezar

- Necesitas una cuenta gratuita en TryHackMe — créala en https://tryhackme.com si aún no tienes una.
- La room de Wazuh requiere conexión a la red de TryHackMe. Tienes dos opciones: usar el AttackBox (máquina virtual en el navegador, sin instalación) o conectarte via OpenVPN desde tu Kali.
- El servidor Wazuh tarda 5 minutos en iniciar después de desplegarlo. No intentes acceder antes — mostrará 'Kibana Server is not ready yet'.
- Credenciales del servidor Wazuh en TryHackMe: Usuario: wazuh / Contraseña: TryHackMe!

CONTEXTO

En las sesiones anteriores estudiaste IDS/IPS y SIEM de forma teórica. Wazuh es la herramienta que combina ambos en un solo sistema: actúa como HIDS en cada agente monitoreado y como SIEM al centralizar, correlacionar y visualizar todos los eventos.

En este laboratorio vas a trabajar con un servidor Wazuh real que ya tiene agentes conectados con datos históricos de eventos de seguridad. Tu trabajo es el de un analista SOC: navegar el dashboard, identificar alertas relevantes, entender qué generó cada alerta y determinar su severidad.

LAB 1

Acceder a la room de Wazuh en TryHackMe

Crea tu cuenta, accede a la room y despliega el servidor Wazuh. Este paso configura el entorno completo del laboratorio.

```
# Paso 1 — Ir a la room de Wazuh en TryHackMe:
#   https://tryhackme.com/room/wazuhct

# Paso 2 — Hacer clic en 'Start Machine' en Task 1
#   Esperar 5 minutos antes de continuar

# Paso 3 — Opciones de acceso al servidor:
#
# Opción A (recomendada) — AttackBox en el navegador:
#   Clic en 'Start AttackBox' en la parte superior de TryHackMe
#   Abrir Firefox dentro del AttackBox
#   Navegar a: http://MACHINE_IP  (la IP aparece en la room)

# Opción B — OpenVPN desde tu Kali Linux:
#   Descargar el archivo .ovpn desde TryHackMe → Access
sudo openvpn tu_archivo.ovpn
#   En otra terminal, abrir Firefox y navegar a: http://MACHINE_IP

# Credenciales del dashboard Wazuh:
Usuario:    wazuh
Contraseña: TryHackMe!

# Al iniciar sesión — seleccionar: Global Tenant
# Salida esperada: dashboard principal de Wazuh con métricas
```

LAB 2

Explorar el dashboard y los agentes

Familiarízate con la interfaz de Wazuh. Identifica los agentes monitoreados, su estado y las métricas generales de seguridad.

```
# Navegación principal del dashboard:

# 1. Ver agentes conectados:
#    Menú superior → Wazuh → Agents
#    Salida esperada: lista de agentes (probablemente 2 agentes)
#    Nota: los agentes aparecerán como 'Disconnected' — es normal en TryHackMe

# 2. Ver resumen de eventos de seguridad:
#    Menú → Security Events
#    Cambiar el rango de fechas para incluir datos históricos
#    Salida esperada: gráficas de eventos por tipo y severidad

# 3. Ver vulnerabilidades detectadas:
#    Seleccionar un agente → Vulnerability Assessment
#    Salida esperada: lista de CVEs detectados en el sistema del agente

# 4. Ver el score de compliance:
#    Seleccionar un agente → Security Configuration Assessment
#    Salida esperada: puntuación del agente contra NIST, MITRE y GDPR

# Tomar captura de pantalla de la lista de agentes para el entregable
```

LAB 3

Analizar eventos de autenticación — intentos de login fallidos

Wazuh monitorea todos los intentos de autenticación. Busca y analiza las alertas de intentos de login fallidos por SSH — uno de los ataques más comunes en sistemas Linux.

```
# Navegar a Security Events del agente Linux

# Filtrar por intentos de login fallidos:
#   En el buscador de Security Events escribir:
rule.id: 5710
#   Rule ID 5710 = intento de login SSH con usuario inexistente

# Alternativamente filtrar por descripción:
rule.description: 'sshd: Attempt to login using a non-existent user'

# Para cada alerta identificada, expandir el evento y anotar:
#   - IP de origen del intento
#   - Usuario que intentó usar
#   - Timestamp del evento
#   - Nivel de severidad (1-15 en Wazuh)

# Ver el log original completo:
#   Expandir la alerta → campo 'full_log'
sshd[1234]: Invalid user admin from 192.168.x.x port 54321

# Pregunta clave: ¿cuántos intentos fallidos hay desde la misma IP?
# Un patrón de muchos intentos desde una IP = fuerza bruta

# Tomar captura de pantalla de los eventos filtrados para el entregable
```

LAB 4

Analizar cambios en archivos críticos del sistema (HIDS)

El agente HIDS de Wazuh monitorea cambios en archivos críticos del sistema operativo. Este es el tipo de detección que ningún NIDS puede hacer — ocurre después del descifrado, dentro del host.

```
# Buscar alertas de integridad de archivos (File Integrity Monitoring):
#   Security Events → filtrar por:
rule.groups: syscheck

# Estas alertas indican que un archivo del sistema fue modificado.
# Expandir una alerta y buscar los campos:
#   syscheck.path     = ruta del archivo modificado
#   syscheck.event    = added / modified / deleted
#   syscheck.md5_after = nuevo hash MD5 del archivo

# Archivos críticos que Wazuh monitorea por defecto en Linux:
/etc/passwd
/etc/shadow
/etc/sudoers
/bin/
/usr/bin/
```

```
# Ver la configuración de FIM en el agente:
#   Management → Configuration → Syscheck
#   Aquí se define qué archivos se monitorean y con qué frecuencia

# Pregunta clave: si un atacante modifica /etc/passwd para agregar
# un usuario nuevo, ¿qué alerta generaría Wazuh y con qué severidad?

# Tomar captura de una alerta de syscheck para el entregable
```

LAB 5

Explorar el sistema de reglas de Wazuh

Las reglas de Wazuh definen qué eventos generan alertas y con qué severidad. Entender la estructura de una regla es entender cómo el SIEM decide qué es relevante y qué es ruido.

```
# Navegar a las reglas del sistema:
#   Wazuh → Management → Rules

# Buscar la regla que detecta intentos de login SSH:
# En el buscador escribir: 5710

# Estructura de una regla de Wazuh:
# <rule id='5710' level='5'>
#   <if_sid>5700</if_sid>
#   <match>Invalid user</match>
#   <description>sshd: Attempt to login using a non-existent user</description>
#   <mitre>
#     <id>T1110</id>  ← MITRE ATT&CK: Brute Force
#   </mitre>
# </rule>

# Campos clave de una regla:
# id       = identificador único de la regla
# level    = severidad (1=bajo, 15=crítico)
# match    = texto que debe aparecer en el log para activar la regla
# mitre    = técnica de MITRE ATT&CK correspondiente

# Ver la ruta completa de las reglas en el servidor:
/var/ossec/ruleset/rules/

# Tomar captura de la regla 5710 para el entregable
```

LAB 6 RETO

Usar la API de Wazuh para obtener información del servidor

Wazuh tiene una API REST que permite consultar el estado del servidor, los agentes y las alertas de forma programática. Este es el mismo mecanismo que usan los SIEMs para integrarse con Wazuh.

```
# Acceder a la consola API de Wazuh:
#   Wazuh (ícono superior izquierdo) → Tools → API Console

# Consulta 1 — Información del servidor:
GET /
# Salida esperada: versión de Wazuh, hostname, tipo de nodo
```

```
# Consulta 2 — Lista de agentes:
GET /agents
# Salida esperada: JSON con todos los agentes, su ID, nombre y estado

# Consulta 3 — Estadísticas de alertas:
GET /manager/stats
# Salida esperada: número total de alertas por nivel de severidad

# Herramienta de línea de comandos equivalente (curl):
# La herramienta estándar de Linux para hacer requests HTTP es:
curl

# Ejemplo de request con curl desde terminal:
curl -k -X GET 'https://MACHINE_IP:55000/' -H 'Authorization: Bearer TOKEN'

# Pregunta clave: ¿qué ventaja tiene usar la API sobre el dashboard
# para un equipo SOC que maneja múltiples instancias de Wazuh?

# Tomar captura de una respuesta de la API para el entregable
```

ENTREGABLE

- screenshot_agentes — Panel de Agents mostrando los agentes disponibles con su estado.
- screenshot_login_fallidos — Security Events filtrados por Rule ID 5710 con al menos 3 alertas de login fallido visibles.
- screenshot_syscheck — Al menos una alerta de File Integrity Monitoring (grupo syscheck) expandida mostrando el archivo afectado.
- screenshot_regla_5710 — Vista de la regla 5710 en Management → Rules mostrando su estructura completa.
- screenshot_api — Respuesta de al menos una consulta a la API de Wazuh desde la API Console. (Reto)
- reflexion — Respuestas a las 3 preguntas de reflexión (mínimo 3 líneas por pregunta).

Nombre del .pdf: `Apellido(s)_Nombre(s)_Lab3.pdf`

PREGUNTAS DE REFLEXIÓN

1. En el laboratorio viste alertas generadas por intentos de login SSH fallidos (Rule ID 5710, nivel 5). Un atacante hace 500 intentos fallidos en 60 segundos desde la misma IP. ¿Qué regla adicional de Wazuh esperarías que se activara para detectar ese patrón como fuerza bruta, y cuál debería ser su nivel de severidad comparado con la regla 5710?
2. El File Integrity Monitoring (FIM) de Wazuh detecta cambios en archivos del sistema. Si un atacante ya tiene acceso root y modifica /etc/passwd para agregar un usuario backdoor, Wazuh generará una alerta. Sin embargo, si el atacante primero desactiva el agente Wazuh y luego modifica el archivo, la alerta no se genera. ¿Cómo

diseñarías una arquitectura de monitoreo que detecte incluso la desactivación del agente?

3. Wazuh es una herramienta open source y gratuita. Splunk y Microsoft Sentinel son herramientas comerciales que cuestan miles de dólares por mes. Basándote en lo que viste en el laboratorio, ¿en qué escenario organizacional recomendarías Wazuh sobre Splunk, y en cuál recomendarías Splunk sobre Wazuh? ¿Qué capacidades específicas justifican la diferencia de costo?

RECURSOS

- [TryHackMe] Room Wazuh (este laboratorio) — https://tryhackme.com/room/wazuhct — gratuito
- [TryHackMe] Room Custom Alert Rules in Wazuh — https://tryhackme.com/room/customalertrulesinwazuh — premium
- [Docs] Wazuh — Documentación oficial completa — https://documentation.wazuh.com/ — gratuito
- [Docs] Wazuh — Reglas predefinidas disponibles — https://github.com/wazuh/wazuh-ruleset — gratuito
- [Docs] MITRE ATT&CK — Framework de técnicas de ataque referenciadas por Wazuh — https://attack.mitre.org/ — gratuito